



ISMS India Information Security Risk Management Methodology

Document Control

Document Title:	Information Security Risk Management Methodology
Current version#:	3.0
Current issue/effective date:	27 Nov 2024
Original version date:	16 Aug 2022
Next Review Due:	Nov, 2025
Created By:	Tim Quaintance, SVP, ISO NA Connie Ford, Director, ISO NA Sanjoy Karmakar, Asst Manager IT, India
Approved By:	Ipsos Global Head of Information Security John van Loenen
Document Owner:	India ISMS Core Team

Revision History

Version	Date	Author	Comments
1.0	16 Aug 2022	Tim Quaintance, SVP, ISO NA Connie Ford, Director, ISO NA	Final, initial version approved by John van Loenan
2.0	26 Apr 2023	Tim Quaintance, SVP, ISO NA Connie Ford, Director, ISO NA Sanjoy Karmakar, Asst Manager IT, India	Introducing new approach combining both quantitative and qualitative risk assessment by identifying information asset based on asset type People, Process & Technology.
3.0	27 Nov 2024	Tim Quaintance, SVP, ISO NA Connie Ford, Director, ISO NA Sanjoy Karmakar, Manager IT, India	Reviewed and no changes

Note: Records within this table will not generate a change in the version number.

ISMS controlled document

Contents

1. Scope	4
2. Overview	4
3. Information Asset Identification	4
4. Threat Assessment	5
5. Vulnerability Assessment	5
6. Risk Identification	6
7. Impact Assessment.....	6
8. Likelihood Assessment	8
9. Inherent Risk Evaluation.....	9
10. Controls Assessment.....	9
11. Residual Risk.....	11
11.1 Actual Risk Value.....	11
11.2 Threshold for Acceptance Risk	11
12. Risk Treatment	12
12.1 Risk Retention/Acceptance	12
12.2 Risk Reduction/Mitigation	12
12.3 Risk Avoidance/Removing risk source	12
12.4 Risk Transfer	12
12.5 Taking/Increasing Risk to pursue Opportunity	12
13. Statement of Applicability.....	13
14. Risk Monitoring and Reporting.....	13
15. Regular Review	13
Appendix I.....	14
A.1 – Vulnerabilities.....	14

1. Scope

This document outlines the Risk Management Framework for activities within Ipsos – India (hereafter referred to as “Ipsos”) and all of its operations and entities included within the scope of its Information Security Management System (ISMS).

2. Overview

Risk management is part of the organization’s day-to-day operations and is undertaken at the entity, business unit, and service levels. The overall aim of risk management process within Ipsos is to identify and manage risks – risks with positive impacts also called opportunities and risks with negative impact in accordance with organizational goals and objectives.

Risk influences every aspect of the operations at Ipsos. Understanding the risks, the company may face and managing them appropriately will enhance the ability to make better decisions, safeguard assets, and provide services to clients and to achieve the organizations goals and objectives.

The organization views the management of risks to its people, assets and all aspects of its operations as an important responsibility. It is committed to upholding its moral, ethical and legal obligations by implementing and maintaining a level of risk management which protects and supports these responsibilities.

An effective Risk Management Framework is not only good business practice but provides organizational resilience, confidence and benefits including:

1. Provides a rigorous decision-making and planning process; Provides the organization with the flexibility to respond to unexpected threats;
2. Takes advantage of opportunities and provides competitive advantage;
3. Provides managers with tools to anticipate changes and threats they face and to allocate appropriate resources;
4. Provides assurance to management and stakeholders that critical risks are being managed appropriately within the organization; and
5. Enables better business resilience and compliance management.

3. Information Asset Identification

Ipsos assesses risks for the resources documented in the inclusions section of the Information Security Management System Scope.

Information assets are a critical component of Ipsos's operations and require appropriate identification and management. Ipsos shall implement a process for identifying and managing information assets based on the asset type as People, Process, and Technology.

Table 1 – Asset Identification

Asset Type	Description
People	Identify the individuals who are involved in the creation, management, and use of information assets. This could include employees, contractors, vendors, and other stakeholders.
Process	Identify the processes that are involved in the creation, management, and use of information assets. This could include processes for data entry, storage, retrieval, analysis, and dissemination.
Technology	Identify the technology that is involved in the creation, management, and use of information assets. This could include hardware, software, networks, and other technology tools.

4. Threat Assessment

Ipsos identifies threats to the identified assets by considering the threat actors listed in the table below. Threat scenarios outside of this table shall be considered as well as related to each identified asset or asset category.

Table 2 – Threats

Threat	Description
Hostile Insiders	People who work in the organization that deliberately compromise the confidentiality, integrity, or availability of an information asset.
Non-hostile Insiders	People who work in the organization that accidentally compromise the confidentiality, integrity, or availability of an information asset.
Hostile Outsiders	People who are external to the organization that deliberately compromise the confidentiality, integrity, or availability of an information asset.
Non-hostile Outsiders	People who are external to the organization that accidentally compromise the confidentiality, integrity, or availability of an information asset.
Technical Problems	Software defects, hardware defects, system crashes and malicious code.
Dependency Problems/Outages	Problems with critical infrastructure like the power supply or telecommunications; problems with third-party service providers.
Legal	Violation of rules and regulations / breach of legislation, failure to meet contractual requirements, unauthorized use of IPR protected resources, abuse of personal data, judiciary decision/court order.
Environmental	Natural disasters, pandemics, social movements, war, terrorist attacks.

5. Vulnerability Assessment

Ipsos identifies the vulnerabilities of information assets by considering applicable weaknesses from the different types of attacks associated with the vulnerabilities listed in the table included as Appendix I. Vulnerabilities outside of this table may be considered as well.

6. Risk Identification

A brief description of the exploit scenario is provided for each threat-vulnerability pair established during the identification phase. See Table-1 Threats and Appendix A-1 Vulnerabilities.

7. Impact Assessment

Ipsos will consider the potential confidentiality, integrity, and availability impact for all identified risk scenarios.

Ipsos uses the selected impact criteria defined in the table below to assign an appropriate business impact associated with the identified risk.

Table 3 - Potential Impact Definitions for Security & Business Objectives

Security & Business Objectives	High Impact=3	Medium Impact=2	Low Impact=1
Confidentiality	The unauthorized disclosure of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. Example(s): - Damage to client - Sensitive information/data/analysis reaches the wrong people/client, unintended hands	The unauthorized disclosure of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. Example(s): - Moderately damaged reputation from exposure of information or non-compliance with industry standards (e.g. Insights Assoc, ESOMAR, etc.)	The unauthorized disclosure of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. Example(s): - Exposure of information that is already public record - Exposure of information out-of-context (i.e. no file layout)
Integrity	The unauthorized modification or destruction of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. Examples:	The unauthorized modification or destruction of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized modification or destruction of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.

Security & Business Objectives	High Impact=3	Medium Impact=2	Low Impact=1
	- Impaired rights of client, Missed deadlines for court filings - Loss of client or irreparable damage to reputation - Substantial fines or lawsuits for non-compliance with laws or regulations - Significant financial losses to compensate clients for errors		Example(s): - Client inconvenienced (e.g. additional copy of ESI required for Litigation Support) - Minor delays or re-work that does not impact a project's profitability, but may reduce client's overall satisfaction with the project (e.g. restores of data from backups)
Availability	The disruption of access to or use of information or an information system could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. Examples: - Unable to file by deadline, Missed appearances in court	The disruption of access to or use of information or an information system could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. Example(s): - Inaccurate results/analysis or loss of data availability that leads to moderate delays or extra costs, and results in client dissatisfaction and reduced project project profitability	The disruption of access to or use of information or an information system could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.

8. Likelihood Assessment

Ipsos assesses the probability of a threat exploiting an asset's vulnerability by evaluating the associated risk likelihood using criteria listed in the table below.

Table 4 - Likelihood Assessment Criteria

Rating	Criteria
High Probability =3	Motive: Threat doesn't need malicious intent to exploit the vulnerability AND Means: Threat doesn't need much time/skill to exploit vulnerability AND Opportunity: Threat has ample opportunity to create the risk by exploiting the existing vulnerability (e.g. risk has occurred multiple times in the past or could occur multiple times in the future) Examples: Once in a month or quarter (power outage, virus alerts)
Medium Probability =2	Motive: Threat has malicious intent OR Means: Threat has skill to exploit vulnerability AND Opportunity: Threat has some opportunity to create the risk by exploiting the existing vulnerability (e.g. risk has occurred once or could occur in the future) Examples: Once in a year (theft, fire)
Low Probability =1	Motive: Threat has malicious intent OR Means: Threat has time/skill to exploit vulnerability OR Opportunity: Threat has little opportunity to create the risk by exploiting the existing vulnerability (e.g. risk has not occurred before and unlikely to occur in the future) Examples: Not happened in last 3 years (flood, earthquake)

9. Inherent Risk Evaluation

Ipsos assesses the security risk of threats exploiting an asset's vulnerabilities by evaluating a combination of the likelihood and impact.

Table 5 - Inherent Risk Evaluation Criteria

IMPACT	High	Medium	High	High
	Medium	Low	Medium	High
	Low	Low	Low	Medium
		Low	Medium	High
		LIKELIHOOD		

Table 6 - Inherent Risk Value Evaluation Criteria

Impact Value	3	3	6	9
	2	2	4	6
	1	1	2	3
		1	2	3
		Likelihood Value		

Inherent Risk Value is calculated by multiplying the Impact Value & Likelihood Value.

Table 7 – Risk Evaluation Definitions

Risk Level	Definition
High	The likelihood of a risk event(s) occurring is "Probable in Some Circumstances." If the risk event(s) occurred, the impact on product delivery and/or data confidentiality would be material, potentially impacting the availability and/or integrity of the product or possible data breach.
Medium	The likelihood of a risk event(s) occurring is "Possible in Limited Circumstances." If the risk event(s) occurred, the impact on product delivery and/or data confidentiality would be moderate, potentially impacting the availability and/or integrity of the product with a moderate chance of a data breach.
Low	The likelihood of a risk event(s) occurring is "Improbable." If the risk event(s) occurred, the impact on product delivery and/or data confidentiality would be minimal with limited risk of a data breach.

10. Controls Assessment

Ipsos identifies the controls implemented to protect the organization from risk and assesses the maturity of the risk mitigation using the criteria listed below.

Annex A of the ISO/IEC 27001 standard will be used as the starting point for the identification of appropriate controls to address the risk treatment requirements identified as part of the risk assessment exercise.

In the event that the controls set out in Annex A do not address all requirements, additional controls may be implemented.

Table 9 - Controls Assessment Criteria

Maturity	Criteria
High=1	Documented policy, procedures and/or technical controls exist for the control and the control objective is achieved.
Medium=2	No documented policy, procedures and/or technical controls exist but the control objective is achieved.
Low=3	Documented policy, procedures and/or technical controls exist but the control objective is not achieved.
Non-Existent	No documented policy, procedures and/or technical controls exist and the control objective is not achieved.

11. Residual Risk

Residual risk is the threat that remains after adjusting for controls in place. Calculation of residual risks allows for the scoring and ranking of risks.

Once residual risk as High, Medium & Low will be obtained from the Table -10, will define the Residual Risk Value as High=3, Medium=2, Low=1.

Table 10 – Residual Risk Assessment Criteria

Maturity of Controls	Non-Existent	Low	High	High
	Low	Low	Medium	High
	Medium	Low	Low	Medium
	High	Low	Low	Low
		Low	Medium	High

Inherent Risk Score

11.1 Actual Risk Value:

Actual Risk Value will be calculated by multiplying the Maturity Value & Residual Value. Based on actual risk value, risk treatment plan will invoke.

Table 11 - Actual Risk Value Evaluation Criteria

Maturity Value	1	1	2	3
	2	2	4	6
	3	3	6	9
		1	2	3

Residual Value

Table 12 – Risk Evaluation Rating

Actual Risk Criteria	Color Code	Risk Rating
High Risk		6 to 9
Medium Risk		3 to 5
Low Risk		1 to 3

11.2 Threshold for Acceptable Risk:

Ipsos, after internal assessment of exposure of risk impact and related business impact, have decided that the threshold for acceptable risk is 1 to 5 and for all exposure above this Ipsos shall implement risk treatment plan or controls to reduce the risk to acceptable level.

12. Risk Treatment

Risk treatment is required for all risks scored as high in the actual risk value category. Generally, medium, low, and negligible rated risks do not require treatments, however, the Global Head of Information Security or SVP-ISO may elevate these risks and require a treatment plan.

Risk treatment plans must be formally documented and should include assignment of the risk owner. The risk owner is responsible for formal acceptance of the risk treatment plan to be tracked by the ISMS Core Team. Risk treatment plans should be reviewed regularly until closure and approval.

Ipsos implements one of five different methods for treating the identified risks:

- Risk Retention/Acceptance
- Risk Reduction/Mitigation
- Risk Avoidance/Removing risk source.
- Risk Transfer
- Taking or increasing risk in order to pursue an opportunity.

11.3 Risk Retention/Acceptance

Risk retention or acceptance occurs when the cost or consequence of managing a risk outweighs the benefit. Risks determined to be negligible, low, and medium are generally retained or accepted unless elevated for treatment. Risks that are high generally require treatment by another method unless compelling evidence for retention is documented.

11.4 Risk Reduction/Mitigation

Ipsos recommends applying appropriate controls to reduce the risks to an acceptable level.

11.5 Risk Avoidance/Removing risk source.

Ipsos recommends avoiding risks by not allowing actions that would cause the risks to occur / expose the organization to the threat. Ipsos will utilize technology and other controls to remove a risk source whenever and wherever possible.

11.6 Risk Transfer

Ipsos recommends sharing the associated risks to other parties, e.g. insurers or suppliers.

However, the transferred risk will be monitored as part of Vendor Management Program.

11.7 Taking or increasing risks in order to pursue an Opportunity.

Ipsos may be willing to accept additional risks in the short term in order to pursue new opportunities. This will be a business decision based on a cost/benefit analysis. We will work to reduce/mitigate these risk ASAP in the future.

13. Statement of Applicability

Based on the Risk Assessment results, the Statement of Applicability will identify the controls from Annex A of the ISO/IEC 27001 standard that are selected based on the risk assessment.

14. Risk Monitoring and Reporting

As part of the implementation of new controls and the maintenance of existing ones, key performance indicators will be identified which will allow the measurement of the success of the controls in addressing the relevant risks.

These indicators shall be reported on a regular basis and trend information produced so that exception situations can be identified and dealt with by management.

15. Regular Review

In addition to a full annual review, risk assessments should be regularly evaluated to ensure that they remain current and the applied controls valid. The relevant risk assessments will also be reviewed for significant changes to the business such as office moves, mergers, and acquisitions or introduction or new or changed IT services.

Appendix I

A.1 – Vulnerabilities

Table 13 – Vulnerabilities

Vulnerabilities	Attacks/Organizational Context
Usage of Unauthorized Devices	Attackers continually scan for new, unprotected systems, including test or experimental systems, and exploit such systems to gain control of them.
Usage of Unauthorized Software	Attackers distribute hostile content on Internet-accessible (and sometimes internal) websites that exploit unpatched and improperly secured client software running on victim machines.
	Attackers continually scan for vulnerable software and exploit it to gain control of target machines.
	Attackers use currently infected or compromised machines to identify and exploit other vulnerable machines across an internal network.
Insecure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers	Attackers distribute hostile content on Internet-accessible (and sometimes internal) websites that exploit unpatched and improperly secured client software running on victim machines.
	Attackers exploit weak default configurations of systems that are more geared to ease of use than security.
Poor Patch Management / Missing Patches	Attackers continually scan for vulnerable software and exploit it to gain control of target machines.
	Attackers exploit new vulnerabilities on systems that lack critical patches in organizations that do not know that they are vulnerable because they lack continuous vulnerability assessments and effective remediation.
	Attackers compromise target organizations that do not exercise their defenses to determine and continually improve their effectiveness.
Lack of Malware policies or controls	Attackers exploit new vulnerabilities on systems that lack critical patches in organizations that do not know that they are vulnerable because they lack continuous vulnerability assessments and effective remediation.

Vulnerabilities	Attacks/Organizational Context
	Attackers compromise target organizations that do not exercise their defenses to determine and continually improve their effectiveness.
	Attackers use malicious code to gain and maintain control of target machines, capture sensitive data, and then spread it to other systems, sometimes wielding code that disables or dodges signature-based anti-virus tools.
	Attackers scan for remotely accessible services on target systems that are often unneeded for business activities, but provide an avenue of attack and compromise of the organization.
Insecure Application Software	Attackers exploit weak application software, particularly web applications, through attack vectors such as SQL injection, cross-site scripting, and similar tools.
Insecure Wireless Access	Attackers exploit wireless access points to gain entry into a target organization's internal network, and exploit wireless client systems to steal sensitive information.
Gaps in Security Knowledge, Skills, or Abilities	Attackers exploit users and system administrators via social engineering scams that work because of a lack of security skills and awareness.
	Attackers trick a user with an administrator-level account into opening a phishing-style e-mail with an attachment or surfing to the attacker's content on an Internet website, allowing the attacker's malicious code or exploit to run on the victim machine with full administrator privileges.
Insecure Configurations for Network Devices such as Firewalls, Routers, and Switches	Attackers use currently infected or compromised machines to identify and exploit other vulnerable machines across an internal network.
	Attackers exploit weak default configurations of systems that are more geared to ease of use than security.
	Attackers scan for remotely accessible services on target systems that are often unneeded for business activities, but provide an avenue of attack and compromise of the organization.
	Attackers exploit and infiltrate through network devices whose security configuration has been weakened over time by granting, for specific short-

Vulnerabilities	Attacks/Organizational Context
	term business needs, supposedly temporary exceptions that are never removed.
Vulnerable Network Ports, Protocols, and Services	Attackers compromise target organizations that do not exercise their defenses to determine and continually improve their effectiveness.
	Attackers scan for remotely accessible services on target systems that are often unneeded for business activities, but provide an avenue of attack and compromise of the organization.
Uncontrolled Use of Administrative Privileges	Attackers exploit users and system administrators via social engineering scams that work because of a lack of security skills and awareness.
	Attackers trick a user with an administrator-level account into opening a phishing-style e-mail with an attachment or surfing to the attacker's content on an Internet website, allowing the attacker's malicious code or exploit to run on the victim machine with full administrator privileges.
	Attackers escalate their privileges on victim machines by launching password guessing, password cracking, or privilege escalation exploits to gain administrator control of systems, which is then used to propagate to other victim machines across an enterprise.
Insecure Network Boundary	Attackers exploit and infiltrate through network devices whose security configuration has been weakened over time by granting, for specific short-term business needs, supposedly temporary exceptions that are never removed.
	Attackers exploit boundary systems on Internet-accessible DMZ networks, and then pivot to gain deeper access on internal networks.
	Attackers exploit poorly designed network architectures by locating unneeded or unprotected connections, weak filtering, or a lack of separation of important systems or business functions.
Poor Security Logging and Analysis (e.g. insecure/unmonitored logs)	Attackers operate undetected for extended periods of time on compromised systems because of a lack of logging and log review.

Vulnerabilities	Attacks/Organizational Context
Uncontrolled Access (e.g. improper segregation of information or assets, access based on need-to-use vs. need-to-know)	Attackers use malicious code to gain and maintain control of target machines, capture sensitive data, and then spread it to other systems, sometimes wielding code that disables or dodges signature-based anti-virus tools.
	Attackers gain access to sensitive documents in an organization that does not properly identify and protect sensitive information or separate it from non-sensitive information.
	Attackers compromise systems and alter important data, potentially jeopardizing organizational effectiveness via polluted information.
Poor User Account Monitoring and Control (e.g. orphaned user accounts)	Attackers exploit users and system administrators via social engineering scams that work because of a lack of security skills and awareness.
	Attackers compromise inactive user accounts left behind by temporary workers, contractors, and former employees, including accounts left behind by the attackers themselves who are former employees.
Lack of Data Leak prevention policies and controls	Attackers use malicious code to gain and maintain control of target machines, capture sensitive data, and then spread it to other systems, sometimes wielding code that disables or dodges signature-based anti-virus tools.
	Attackers gain access to sensitive documents in an organization that does not properly identify and protect sensitive information or separate it from non-sensitive information.
	Attackers gain access to internal enterprise systems and gather and exfiltrate sensitive information without detection by the victim organization.
	Attackers compromise systems and alter important data, potentially jeopardizing organizational effectiveness via polluted information.
Poor Incident Response and Management	Attackers operate undiscovered in organizations without effective incident response capabilities, and when the attackers are discovered, the organizations often cannot properly contain the attack, eradicate the attacker's presence, or recover to a secure production state.

Vulnerabilities	Attacks/Organizational Context
Insecure Network Architecture	Attackers exploit boundary systems on Internet-accessible DMZ networks, and then pivot to gain deeper access on internal networks.
	Attackers exploit poorly designed network architectures by locating unneeded or unprotected connections, weak filtering, or a lack of separation of important systems or business functions.
Gaps Between Controls Design and Implementation (e.g. policies without technical implementation or enforcement mechanisms)	Attackers compromise target organizations that do not exercise their defenses to determine and continually improve their effectiveness.
	Attackers exploit weak application software, particularly web applications, through attack vectors such as SQL injection, cross-site scripting, and similar tools.
Lack of Physical Access Controls	Individual views confidential information after gaining physical access.
	The layout of an office workspace enables anyone in the area to view confidential information displayed on computer screens.
	Individual modifies information after gaining physical access.
	Individual loses or destroys information after gaining physical access.
	Individual interrupts access to a system or information by using physical access to prevent others from accessing them.
Software Defects	A software defect results in disclosure of information to unauthorized parties.
	A software defect results in modification of information on a system.
	A software defect results in the loss or destruction of information on a system.
	A software defect results in a system crash, preventing access to the system.

Vulnerabilities	Attacks/Organizational Context
System Crashes	A system crashes for unknown reasons (i.e. it cannot be traced to a software defect, hardware defect, malicious code, or actions by people), resulting in disclosure of information to unauthorized parties.
	A system crashes during a lengthy update of a database, corrupting its information.
	A system crashes, destroying any information that was not saved at the time of the crash.
	A system crashes resulting in interruption of access.
Power Supply Problems	A power outage results in loss of any information that was not saved at the time of the outage.
	A power outage prevents access to all key systems.
Telecommunications Problems	Unavailability of telecommunications services leads to interruption of access to a system.
Third Party Problems	Third party service provider views confidential information on a key business system they maintain.
	Problems at a third party service provider lead to the modification of information on a key business system maintained by the provider at their site.
	Problems at a third party service provider lead to the destruction of information on a key business system located at that provider's site and maintained by the provider.
	Problems with services provided by third parties (e.g. maintenance of systems) lead to interruption of access to a system.
Natural Disasters	Natural disasters (e.g. flood, fire, tornado) lead to interruption of access to a system.
	Natural disasters (e.g. flood, fire, tornado) lead to loss or destruction of information.

